

## LAB 10

# GlobalFinance - Yönetim Kuruluna Siber Risk Raporlama

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: Technology Risk Manager

## 1. HİKÂYE

|                                             |                                                                 |
|---------------------------------------------|-----------------------------------------------------------------|
| Sektör<br>Global finansal hizmetler         | Ölçek<br>24.000 çalışan, 17 ülke                                |
| Hedef kitle<br>Yönetim Kurulu Risk Komitesi | Beklenti<br>En fazla 1 sayfalık teknik olmayan siber risk özeti |

GlobalFinance Yönetim Kurulu, artan düzenleyici beklentiler nedeniyle siber risk görünümünü aylık izlemeye karar vermiştir. Teknik ekipler size farklı ölçekte 14 problem göndermiştir. CISO, tüm konuların görünür olmasını isterken CFO yalnızca kurumsal hedefleri etkileyebilecek risklerin rapora girmesini istemektedir. Yönetim Kurulu teknik araç isimleri veya uzun zafiyet listeleri görmek istememektedir. Siz raporun içeriğini ve önceliklendirme mantığını oluşturacaksınız.

## 2. SİZE VERİLEN GÖREV

Teknik sorunları tekrar etmek yerine ortak risk temalarında birleştirin; iş etkisi, eğilim, risk iştahı, mevcut aksiyon ve karar ihtiyacını görünür kılın. Verinin sınırlamalarını saklamayın.

## 3. OLAYLAR VE KANITLAR

### T-01-03 | Zafiyet ve varlık

İnternete açık 12 kritik zafiyet; 10'u 7 gün içinde kapalı, ikisi 21 gündür açık. CMDB'deki sunucuların %8'inin sahibi boş. EDR kapsamı %96; çevrimdışı cihazlar çoğunlukla saha ofislerinde.

### T-04-05 | Kimlik

Ayrıcalıklı hesapların %93'ünde MFA var. Kalan 41 hesap legacy uygulamalarda. Üç aylık access review iki bölgede 18 gün gecikmiş; sonuçta 64 erişim kaldırılmış.

### T-06-07 | Üçüncü taraf

Kritik 86 tedarikçinin 79'u güncel değerlendirmeye sahip. Bir ödeme sağlayıcı SOC raporunu geciktirmiştir. Başka bir sağlayıcı küçük bir olay bildirmiş, müşteri verisi etkilendiğini beyan etmiştir.

### T-08-09 | Dayanıklılık

Ana ödeme platformu DR testi RTO hedefini 37 dakika aşmıştır. İkinci test başarıyla tamamlanmıştır. Yedekleme başarı oranı %99,7; üç kritik uygulamanın tam restore testi yoktur.

### T-10-11 | Olaylar

Kimlik avı tıklama oranı %4,2'den %3,1'e düşmüştür. Bir iş e-postası ihlali 75.000 EUR yanlış ödemeye yol açmış, tutarın %80'i geri alınmıştır. Ödeme için iki onay vardı ancak ikincisi telefonla doğrulamamıştır.

## LAB 10

# GlobalFinance - Yönetim Kuruluna Siber Risk Raporlama

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: Technology Risk Manager

## 3. OLAYLAR VE KANITLAR - DEVAM

### T-12 | Veri koruma

DLP projesi planın iki ay gerisindedir. Bulut depolarının %91'i otomatik sınıflandırılmaktadır. Kalan kapsamda iki satın alınan şirket bulunur; veri envanteri tamamlanmamıştır.

### T-13 | Güvenlik operasyonu

SOC kritik alarmların %88'ini 15 dakika içinde inceler; hedef %95'tir. Metrik yalnızca kapanan alarmları içerir. Açık alarm yaşlandırması raporda yoktur.

### T-14 | Bütçe kararı

Legacy MFA dönüşümü için 1,2 milyon EUR ek bütçe gerekir. İş birimleri kesinti riskinden dolayı geçişi gelecek yıla ertelemek ister. Düzenleyici inceleme altı ay sonradır.

### Yönetim beklentisi

Başkan: 'Geçen aya göre daha mı güvendeyiz ve hangi kararı vermemiz gerekiyor?' CFO: 'Kontrol sayısı değil, olası iş kaybı ve öncelik istiyorum.' CISO: 'Eksik kapsamların da görünür olması şart.'

## 4. ÖĞRENCİNİN GÖREVLERİ

- 14 konuyu 3-5 kurumsal risk temasında konsolide edin.
- Riskleri etki, olasılık, eğilim ve kontrol gücüyle önceliklendirin.
- Olumlu gelişmeler ile önemli açıkları dengeli sunun.
- Yanıtıcı olabilecek metrikleri ve veri sınırlamalarını belirleyin.
- Yönetim Kurulundan beklenen kararları açıkça yazın.
- Legacy MFA bütçe ikilemi için seçenekleri ve riskleri sunun.
- Bir sayfalık, teknik olmayan yönetici özeti tasarlayın.
- Önerdiğiniz KRI'ları eşik ve sahipleriyle tanımlayın.

## 5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- 3-5 kurumsal siber risk teması
- Öncelik ve eğilim tablosu
- Yönetim kararı gereken konular
- KRI önerileri ve veri uyarıları
- En fazla 1 sayfalık Board Executive Summary

### ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:  
volkan@grcustasi.com  
adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM  
GRC Ustası